Writeup-Directory

Información del laboratorio

Plataforma	Whoami-Labs.com
Laboratorio	Directory
IP objetivo	172.17.0.2
Fecha	24/10/2026

Resumen

El laboratorio **Directory** expone un servicio web en Python **(Werkzeug/Flask)** sobre el puerto 8080 con un endpoint de carga de archivos **(/upload)** sin validación de extensión ni de contenido. Esto permitió subir una reverse shell en Python y obtener ejecución remota de comandos como el usuario **kevin**. Posteriormente, el binario **/usr/bin/find** fue identificado con el bit **SUID** activo, lo que permitió escalar privilegios a **root** mediante una técnica documentada en **GTFOBins**.

Vector de ataque:

Subida de archivo malicioso sin restricciones (Unrestricted File Upload), RCE: Escalada de privilegios vía binario SUID mal configurado.

1.Reconocimiento

Escaneo completo de puertos con Nmap:

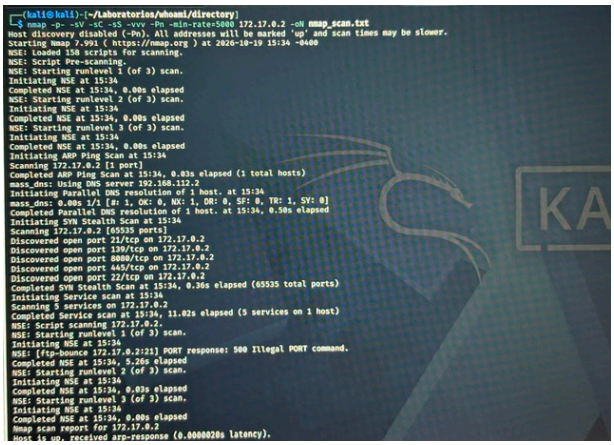
nmap -p- -sV -sC -sS -vvv -Pn --min-rate=5000 172.17.0.2 -oN nmap_scan.txt

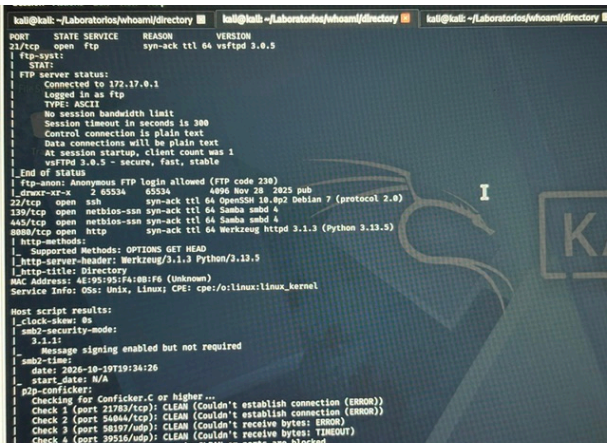
Explicación de parámetros

- **-p-** : Escaneo de los 65535 puertos TCP
- **-sV** : Deteción de versiones.
- **-sC** : Scripts básicos NSE
- **-sS** : SYN Scan.
- **-Pn :** Omitir el descubrimiento inicial del host.
- **--min-rate=5000:** Aumenta la velocidad del escaneo.
- **-oN nmap_scan.txt**: Guarda la salida.

Puerto	Estado	Servicio	Versión
21/tcp	open	ftp	vsFTPd 3.0.5 (login anónimo habilitado)
22/tcp	open	ssh	OpenSSH 10.0p2 Debian
139/tcp	open	netbios-ssn	Samba smdb 4
445/tcp	open	netbios-ssn	Samba smdb 4
8080/tcp	open	http	Werkzeug 3.1.3(python 3.13.5) - título: “Directory”

El hallazgo más relevante del escaneo fue el script ftp-anon, que confirmó acceso anónimo al servicio FTP, y el servicio web expuesto en el puerto 8080, contruido sobre el framework **Flask/Werkzeug.**





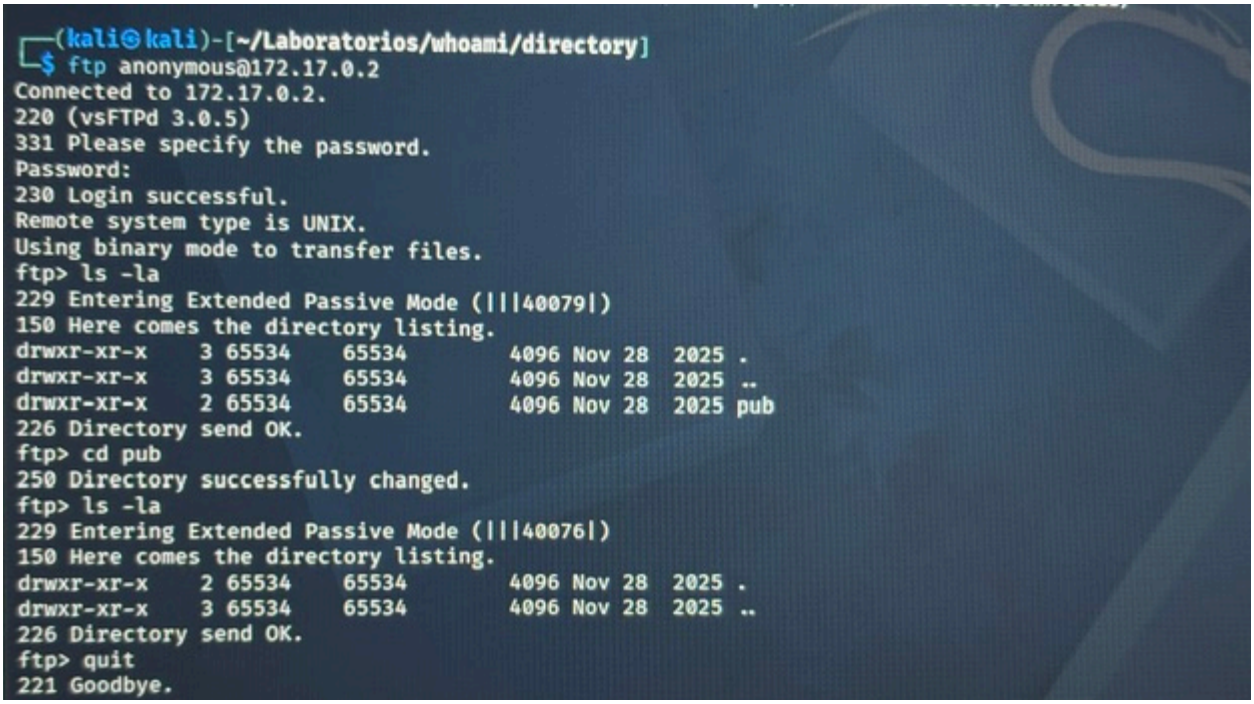
2.Enumeración

2.1 FTP anónimo

Se verificó el acceso anónimo detectado por Nmap:

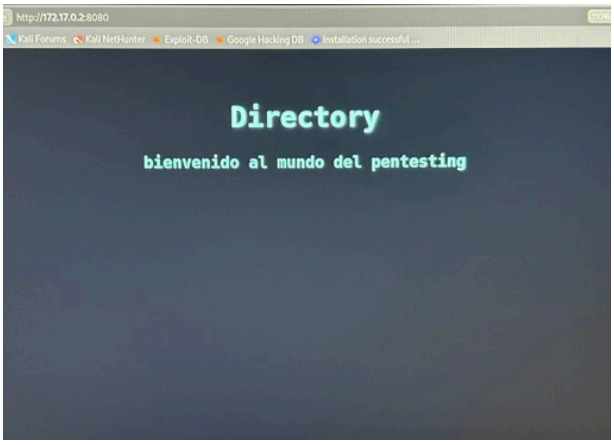
ftp anonymous@172.17.0.2

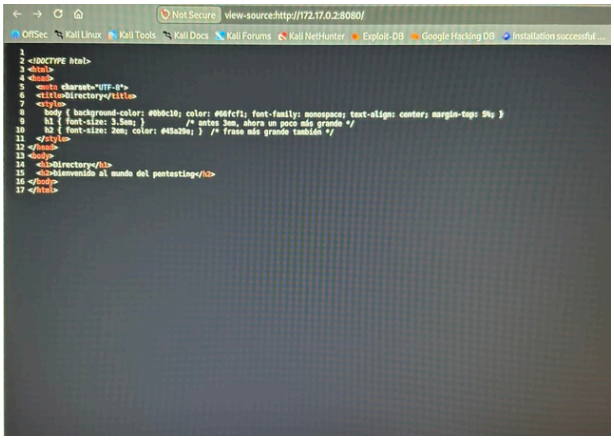
El login fue exitoso (230 login successful), pero el directorio pub estaba vacío, sin archivos de interés.



2.2.Enumeración web (puerto 8080)

Al visitar **http://172.17.0.2:8080** se mostró una página estática simple **(“Directory - bienvenido al mundo del pentesting”)**. El view source confirmó que era **HTML/CSS** estático sin lógica visible ni pistas adicionales.





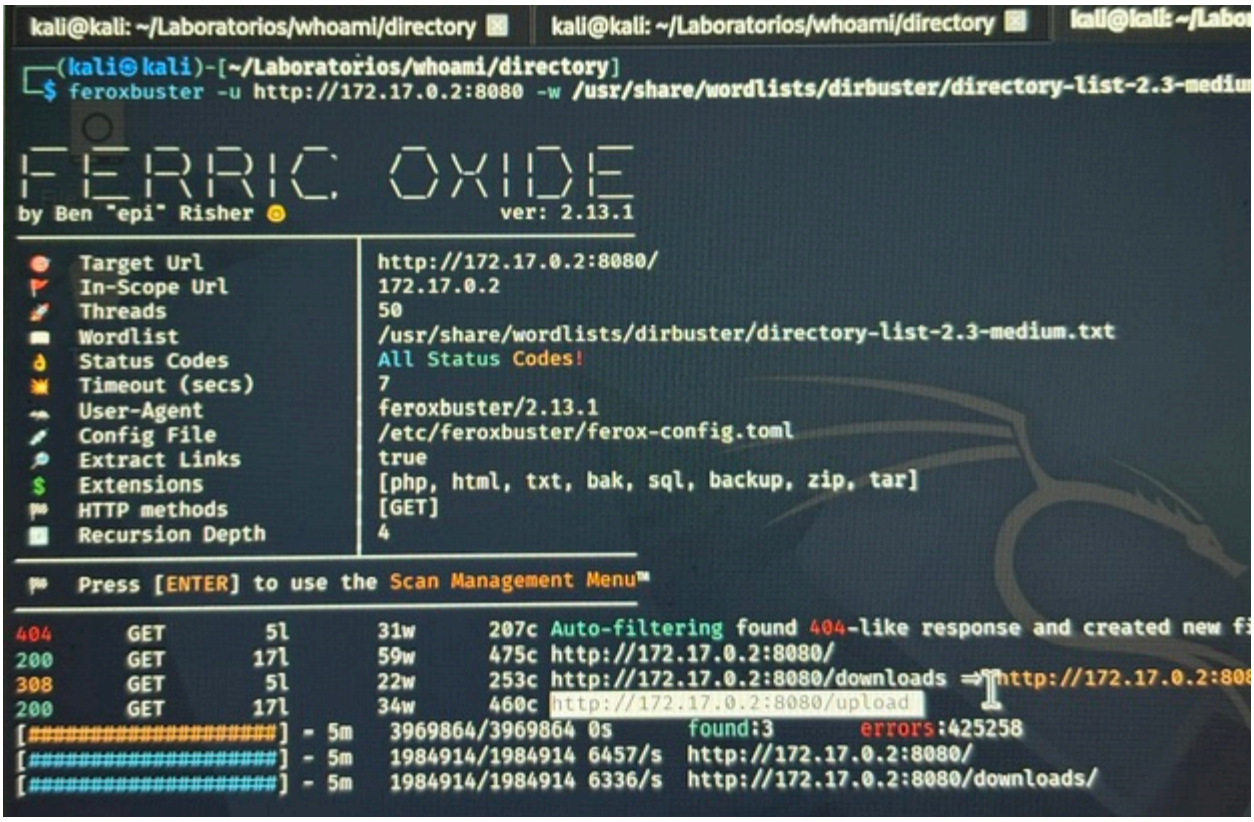
Se realizó fuzzing de directorios con

Feroxbuster:

feroxbuster -u http://172.17.0.2:8080 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt

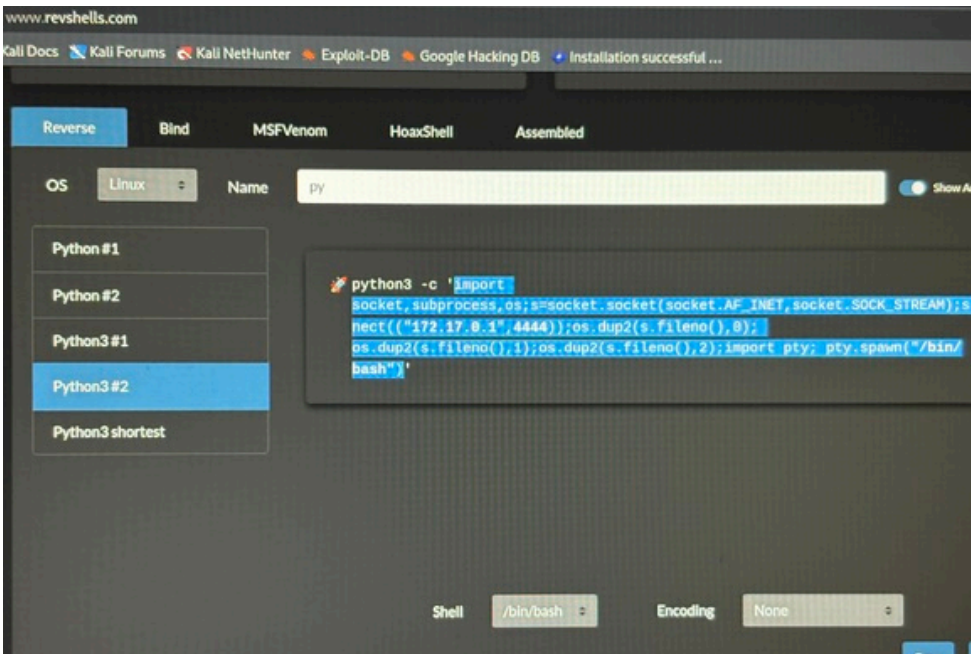
Código	Ruta
200	/
308 (redirección)	/downloads - /downloads/
200	/upload

En /downloads s listó un único archivo, **readme.txt,** cuyo contenido era “Nada especial por aquí..” (un señuelo sin valos). El hallazgo clave fue el endpoint **/upload,** que sugería una funcionalidad de carga de archivos en el servidor **Flask/Werkzeug.**



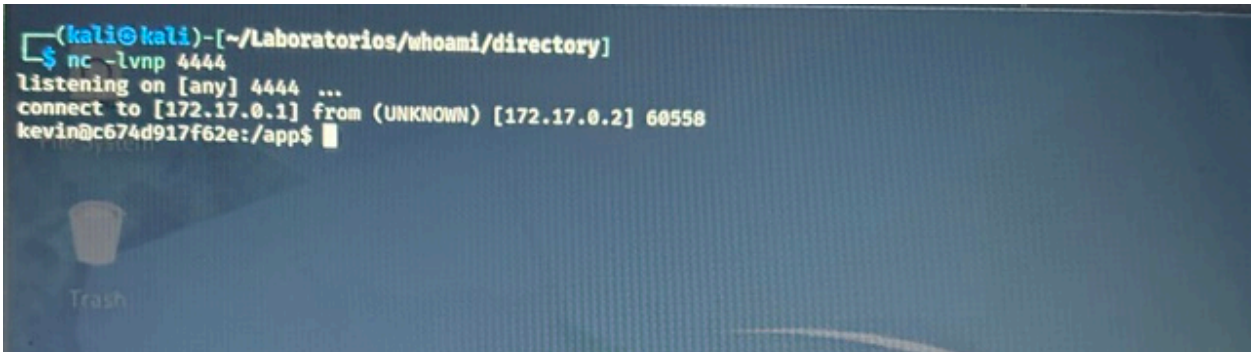
3.Explotación

El endpoint /upload permitía subir archivos arbitrarios sin validar extensión ni contenido **(Unirestricted File Upload).**

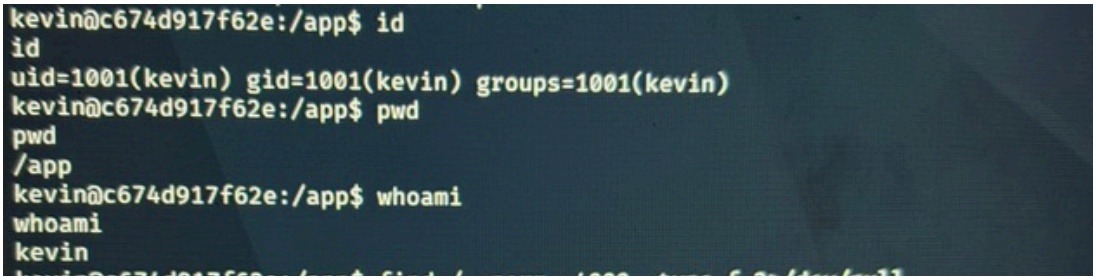




Listener:

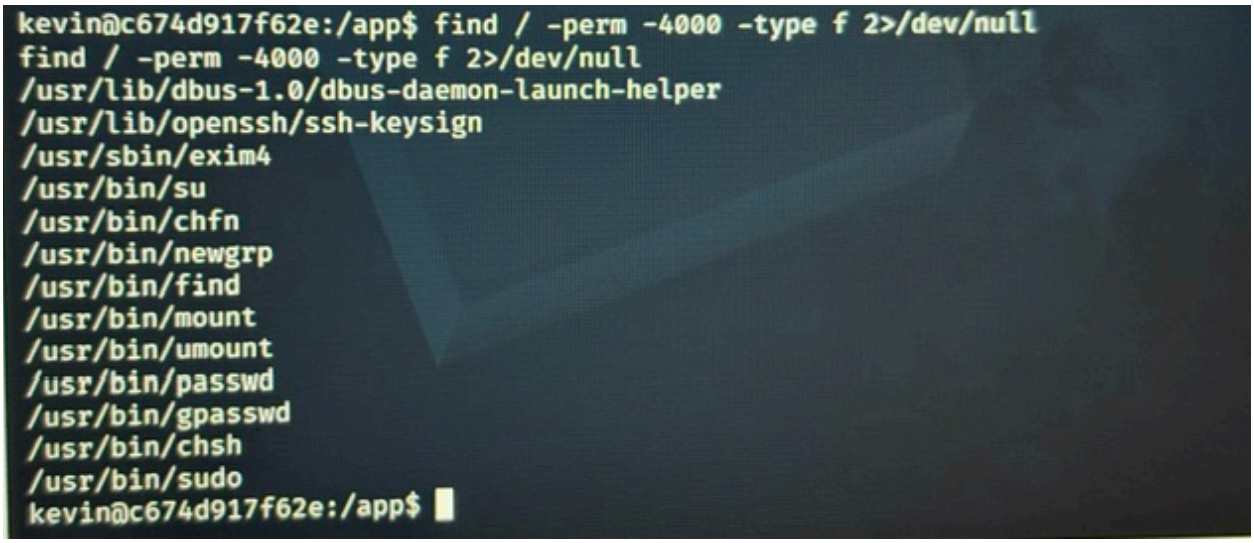


Subida del archivo a través de /upload y ejecución porterior. El listener recibió la conexión entrante.

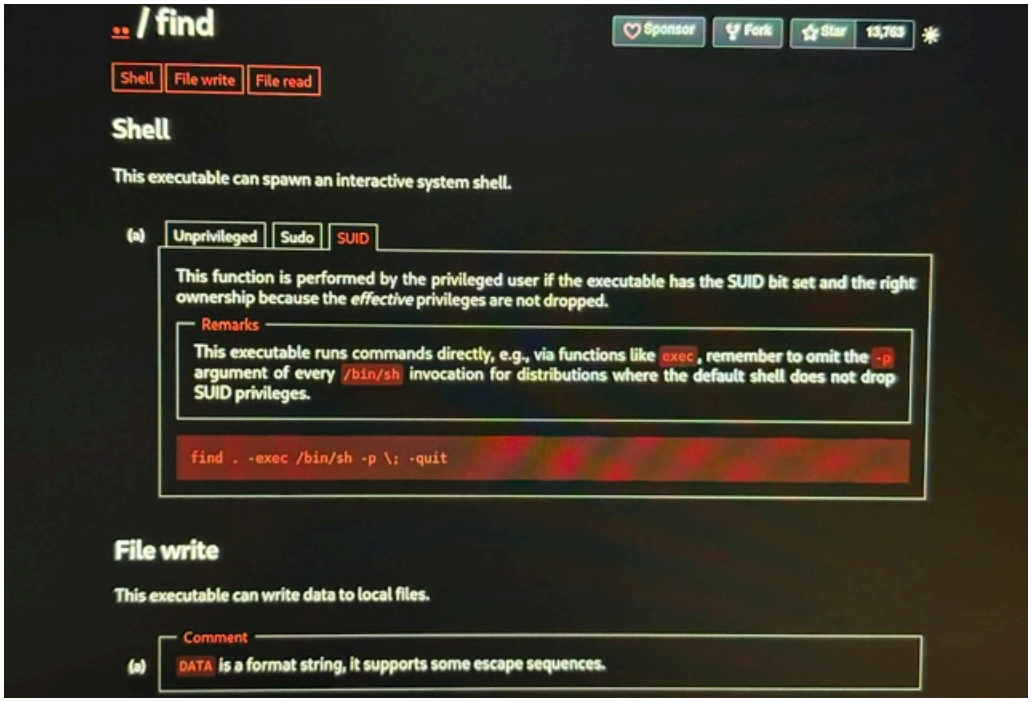


4.Escalada de privilegios

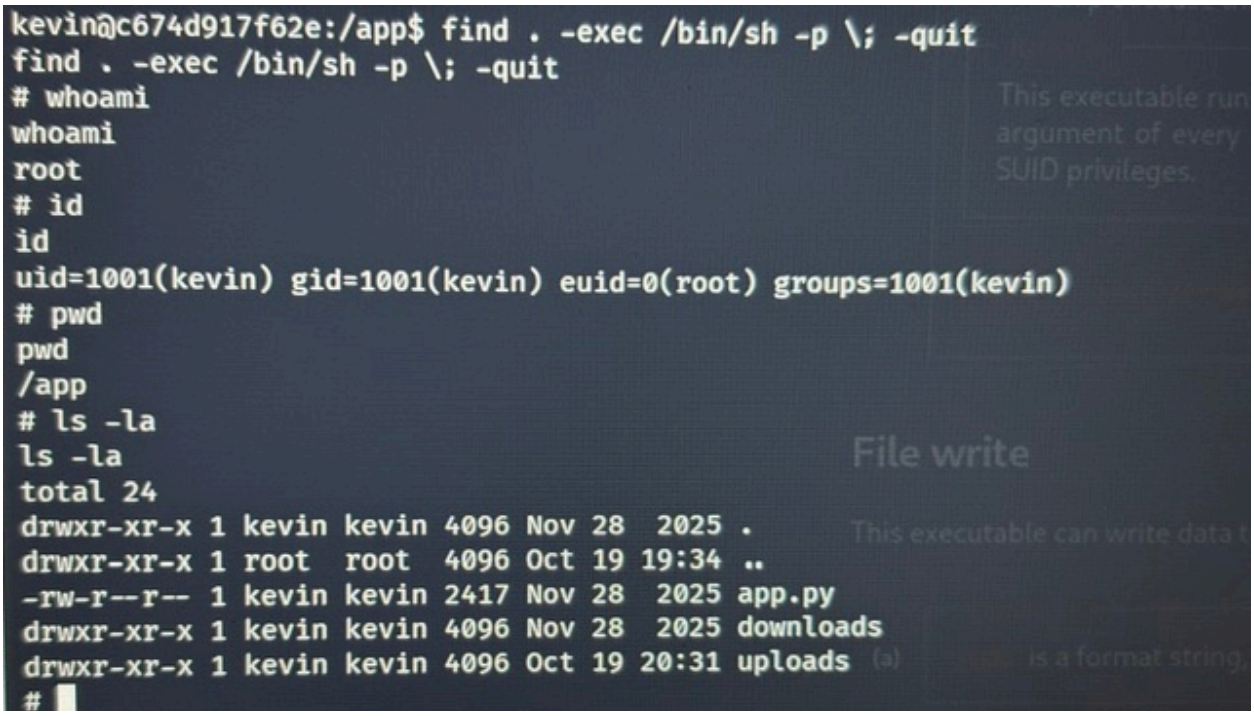
Búsqueda de binarios co el bit SUID activo:



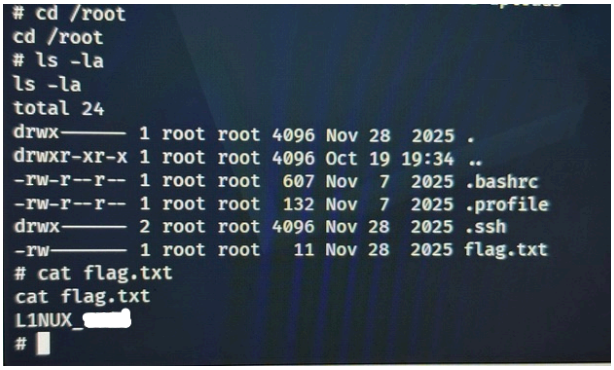
Entre los resultados (su,passwd,sudo,mount,etc) destacó uno fuera de lo común:/usr/bin/find. Que el propio binario find tenga el bit SUID es un mala configuración explotable, documentada en GTFOBins.

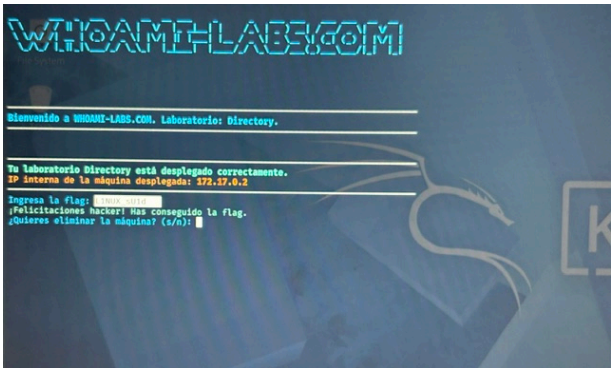


El flag -p es clave: evita que /bin/sh descarte los privilegios efectivos SUID al iniciar.



5.Flag





Conclusión

Este laboratorio ilustra una cadena de ataque clásica: una vulnerabilidad de aplicación web (subida de archivos sin restricciones) como vector de acceso inicial, seguida de una escalada de privilegios trivial por una mala configuración del sistema (binarios SUID innecesario).